

Lab 3C: CI/CD - Claude in Your Pipeline

Duration: 25-30 min

After: Production & CI/CD lecture (Day 3, Block 3)

Prerequisites: Lab 3B complete; GitHub account + `gh` CLI for Phase 2 (Phase 1 needs no GitHub)

Objective

Run Claude Code headless with `claude -p` under explicit `--max-turns` and `--allowedTools` budgets, make the run **idempotent** (safe to re-run) and **fail-safe** (non-zero exit when the cost bound is hit), parse structured JSON output, then wire the official `anthropics/claude-code-action@v1` GitHub Action for **advisory** PR review.

Deliverable (toolkit chain 11 of 12)

A headless review script (`scripts/ci-review.sh`) with an idempotency guard and hard cost bounds, and a `.github/workflows/claude-review.yml` advisory workflow in the toolkit repo.

START MARKER: Regular terminal (NOT inside Claude), `cd business-dashboard`.

Phase 1: Headless Mode (15 min)

Headless = one prompt in, output out, exit code, no conversation. This is Claude as a tool other tools can call.

Step 1 - basic invocation:

```
claude -p "List all JS files in src/ and describe each in one sentence." --allowedTools
"Read,Glob"
```

Expected output marker: a file list prints, then the process exits - no interactive prompt returns.

Two flags you must never omit in CI:

- `--allowedTools "Read,Grep,Glob"` - headless has no human to approve tools; without this Claude can't read files (or with looser settings could do too much).
- `--max-turns 10` - caps the agentic loop so a confused run can't burn tokens forever. This is your **cost bound**: a run that hits it must FAIL the job (non-zero exit), never silently retry - Step 4 wires that in.

Step 2 - pipe input:

```
git log --oneline -10 | claude -p "Generate a markdown changelog from this git log.
Sections: Features, Fixes, Chores." --max-turns 3
```

Expected output marker: a formatted changelog on stdout.

Step 3 - structured JSON:

```
claude -p "Review src/routes/tasks.js. Return JSON:
{\"issues\": [{\"severity\": \"high|medium|low\", \"message\": \"...\"}], \"score\": number}" \
--allowedTools "Read,Grep,Glob" --max-turns 10 --output-format json > review.json
cat review.json
```

Expected output marker: a JSON envelope with `type`, `subtype`, `result`, `session_id`, `total_cost_usd`, `duration_ms`, `num_turns`. Your review text is a string inside `.result`:

```
jq -r '.result' review.json
jq -r '.total_cost_usd' review.json
```

Step 4 - the reusable gate script, now with hard bounds. Create scripts/ci-review.sh:

```
#!/bin/bash
set -e
MAX_TURNS=10

# --- IDEMPOTENCY GUARD: safe re-run (Step 5 explains) ---
SHA=$(git rev-parse HEAD)
MARKER=".ci-review/${SHA}.done"
if [ -f "$MARKER" ]; then
  echo "SKIP: HEAD ${SHA:0:7} already reviewed - re-run is free."; exit 0
fi

claude -p "Review the code in src/ for security and quality issues. Return JSON: {\"issues\": [{\"severity\": \"critical|high|medium|low\", \"message\": \"...\"}], \"score\": number} \" \
--allowedTools \"Read,Grep,Glob\" \
--max-turns $MAX_TURNS \
--output-format json > review.json

# --- COST BOUND FAIL-SAFE: hitting the turn cap is a FAILURE, not a soft landing ---
SUBTYPE=$(jq -r '.subtype // empty' review.json)
TURNS=$(jq -r '.num_turns // 0' review.json)
if [ "$SUBTYPE" = "error_max_turns" ] || [ "$TURNS" -ge "$MAX_TURNS" ]; then
  echo "COST BOUND HIT (${TURNS}/${MAX_TURNS} turns) - failing safe so CI does NOT auto-retry."
  exit 2
fi

SCORE=$(jq -r '.result' review.json | jq -r '.score // 0')
COST=$(jq -r '.total_cost_usd' review.json)
echo "Review score: $SCORE"
echo "Cost: \$$COST"
if (( $(echo "$SCORE < 6" | bc -l) )); then
  echo "REVIEW FAILED (score < 6)"; exit 1
fi

# --- success: leave the marker so the next run on this SHA is a no-op ---
mkdir -p .ci-review && touch "$MARKER"
echo "REVIEW PASSED"
```

```
chmod +x scripts/ci-review.sh && ./scripts/ci-review.sh
```

Expected output marker: Review score: <n>, a cost line, and REVIEW PASSED (exit 0) - or a non-zero exit you can gate on: 1 = quality gate failed, 2 = cost bound hit. This exact script is your capstone CI check tomorrow. It works in ANY CI system: GitHub, GitLab, Azure, Jenkins.

Step 5 - prove the idempotency guard (safe re-run):

```
./scripts/ci-review.sh # second run, same HEAD
echo "exit code: $?"
```

Expected output marker: SKIP: HEAD <sha> already reviewed - re-run is free. and exit code 0 - **no tokens spent**. CI re-fires workflows constantly (synchronize events, manual re-runs, flaky runners); the SHA marker means a re-run never bills twice, posts twice, or edits twice. Commit something small and run again to see a fresh review fire on the new SHA. (Add `.ci-review/` to `.gitignore` - the marker is runner-local state.)

***Loop-to-invoice alerting:** the two guards above stop a single runaway run. The failure mode that makes invoices is the **loop**: a bounded run fails, CI auto-retries it, and the same bill repeats every few minutes all weekend. Log `total_cost_usd` from every run and alert a human channel when a single run exceeds a ceiling (e.g. \$0.50) or a pipeline's daily total crosses a budget - the alert must fire **before** the invoice, not on it. Minimum viable version: one `if on $COST` that posts to your team channel; never rely on the monthly bill as your alarm.*

***Billing note:** this lab uses Claude Code print mode and a GitHub Action, not the Claude Agent SDK. Confirm the runner credential: subscription CLI usage follows the live account allowance; API/cloud credentials are token billed. Eligible Agent SDK plan users may have a separate **monthly** SDK credit, but that is a different execution path.*

Phase 2: GitHub Action - Official, Advisory (10-15 min)

No GitHub access? Phase 1 was the core learning. Read this phase as reference - the instructor will demo.

Step 1 - repo + secret:

```
gh repo create business-dashboard --private --source=. --remote=origin --push
gh secret set ANTHROPIC_API_KEY # paste key when prompted
```

Step 2 - the official Action. Create `.github/workflows/claude-review.yml`:

```
name: Claude PR Review
on:
  pull_request:
    types: [opened, synchronize]

jobs:
  review:
    runs-on: ubuntu-latest
    permissions:
      contents: read
      pull-requests: write
      issues: read
    steps:
      - uses: actions/checkout@v4
      with:
        fetch-depth: 0
      - uses: anthropics/claude-code-action@v1
      with:
        anthropic_api_key: ${ secrets.ANTHROPIC_API_KEY }
        prompt: |
          Review this pull request for security, quality, and test coverage.
          Post findings as a PR comment with severity labels.
          If a review comment from you already exists for this commit, do not post a duplicate.
          This review is ADVISORY - do not fail the check for findings.
        claude_args: "--max-turns 10 --allowedTools Read,Grep,Glob"
```

Note what you did NOT write: no install step, no JSON plumbing, no comment-posting script - the official action handles it. Note what you DID write: the same cost bound (`--max-turns`) and read-only allowlist as Phase 1, plus a no-duplicate instruction - the workflow-level echo of your idempotency guard, since `synchronize` re-fires this job on every push.

Step 3 - trigger with a deliberately bad PR:

```
git checkout -b test-review
cat > src/bad-code.js <<'EOF'
const API_KEY = "sk-1234567890abcdef";
function runQuery(userInput) {
  return `SELECT * FROM users WHERE name = '${userInput}'`;
}
module.exports = { runQuery };
EOF
git add -A && git commit -m "test: add review-bait file"
git push -u origin test-review
gh pr create --title "Test: Claude advisory review" --body "Testing the review workflow"
```

Step 4 - watch:

```
gh run watch
```

Expected output marker: the workflow runs and a Claude comment appears on the PR flagging the hardcoded secret and SQL injection with severities. The check stays green - **advisory** informs, never blocks:

```
gh pr view --comments
```

Step 5 - verify advisory, then clean up. The merge button stays available despite critical findings - that's the advisory contract. Close without merging:

```
gh pr close test-review --delete-branch
git checkout main
```

***Advisory vs gating:** start advisory; graduate to gating (exit-code enforcement like Phase 1's script + branch protection) only after the team calibrates thresholds. Too strict too early = developers route around the bot.*

FINISH MARKER - Success Checklist

- [] `claude -p` ran with BOTH `--allowedTools` and `--max-turns`
- [] JSON envelope parsed: `.result`, `.total_cost_usd`
- [] `scripts/ci-review.sh` runs and exits 0/1 on a score threshold
- [] Cost-bound fail-safe in place: turn-cap hit -> exit 2, job stops (no silent retry)
- [] Idempotency guard proven: second run on the same SHA printed SKIP, exit 0, zero cost
- [] You can state where a loop-to-invoice alert fires and who it pages
- [] `anthropics/claude-code-action@v1` workflow committed
- [] Advisory PR comment received on the bad-code PR (or watched in demo)
- [] You can state when to move advisory -> gating

If Stuck

Problem	Recovery
Headless can't read files	You omitted <code>--allowedTools</code>
<code>jq</code> errors on <code>review.json</code>	The response isn't bare JSON - extract <code>.result</code> first with <code>jq -r '.result'</code>

Problem	Recovery
Script always prints SKIP	Stale marker: <code>rm -rf .ci-review/</code> or commit a change so HEAD moves
<code>.subtype</code> is empty on your build	Envelope fields vary by version - the <code>num_turns</code> check still catches the bound; verify field names with <code>cat review.json</code>
Action fails at auth	<code>gh secret list</code> must show <code>ANTHROPIC_API_KEY</code> ; re-set it
No PR comment appears	Check <code>permissions: pull-requests: write</code> in the workflow
<code>bc</code> not installed	Ask Claude to rewrite the threshold check as an integer compare
Runs slow/expensive	Lower <code>--max-turns</code> ; scope the prompt to changed files only

Debrief Questions

1. What do `--max-turns` and `--allowedTools` each protect you from in CI?
2. Why must hitting the turn cap exit **non-zero** - what does a "successful" truncated run invite your CI to do?
3. Why start advisory instead of gating on day one?
4. Which credential and billing path does this CI run use, and where does the loop-to-invoice alert fire before the platform team sees the bill?